Systems Security Case Study Project

baker0204

Prof. JN

1. **Company Profile**
    a. **Company Name:** Doohickey Depot
    b. **Industry:** Retail & E-commerce
    c. **Size**: Mid-sized company with 200 employees and three regional distribution centers.
    d. **Mission:** To design, sell, and distribute high-quality doohickey apparatuses for industrial and consumer markets.
    e. **Doohickey Depot** relies on many internet-connected IoT devices for tasks such as inventory tracking, customer-facing smart home products, and supply chain management and operations. Because of this heavy reliance, the company faces an increasing risk relating to IoT compromise, payment card security, and operational disruption.
    f. **Key Security Challenges:**
        i. Keeping the IoT Doohickeys from unauthorized access and/or firmware tampering.
        ii. Keeping sensitive company customer payment data and information secure.
        iii. Preventing supply chain manipulation of connected IoT devices before they reach customers.
        iv. Maintaining uptime inventory management and fulfillment systems.
        v. Training staff in secure payment handling and phishing.

2. **Asset Categories**
    a. Data and Information
        i. Assets:
            1. Customer PII (names, addresses, payment information)
            2. Sales and transaction records
            3. IoT device firmware and configuration data
        ii. **Why It's Critical:** Doohickey Depot runs on data; these critical assets drive the business forward, and a compromise of these assets could result in regulatory penalties, fraud losses, and a loss of trust from our customers. Firmware data is especially sensitive because tampering with IoT device code could allow threat actors to weaponize or exploit downstream products.
    b. Applications and Services

i. **Assets:**
    1. E-Commerce Website
    2. Inventory management SaaS system
    3. Payment processing platform (PCI-relevant systems)

ii. **Why It's Critical:** These applications directly control revenue, ordering, and fulfillment. An outage or a compromise could halt operations or lead to unauthorized transactions. Because payment systems touch and interact with regulated data, Doohickey Depot has compliance burdens and heightened exposure.

c. Infrastructure and Networks

i. **Assets:**
    1. Corporate network and VLANs
    2. Cloud-hosted servers supporting the online storefront
    3. Firewalls, IDS, load balancers

ii. **Why It's Critical:** All business systems, IoT device communications, and cloud services pass through the network. A potential breach could provide threat of actors with a point of attack to disrupt operations or steal data. Network security is essential for maintaining uptime and availability in our warehouse sites.

d. Endpoints and Devices

i. **Assets:**
    1. Handheld scanners in the warehouse and IoT inventory sensors
    2. Employee laptops and mobile devices.

ii. **Why It's Critical:** Endpoint systems are often targeted first due to weak configuration, user behavior and error, or even physical access. For Doohickey Depot, IoT sensors that are misconfigured, or compromised scanners can create operational bottlenecks and introduce false and malicious data into inventory systems.

e. People and Identities

i. **Assets:**
    1. Employees with payment system access
    2. Privileged IT admin accounts
    3. Third-party vendors that are involved in the manufacturing of IoT hardware.

ii. **Why It's Critical:** People remain the weakest link in the security posture of the company. Credential theft, phishing, and insider misuse present serious risks to the warehouses and the IoT components of company operations. Vendor access increases the overall complexity and especially when supply chain manipulation of the IoT firmware is a concern for the company.

f. Facilities and Physical Assets

i. Assets:

1. Regional distribution centers
2. Physical security systems (camera, keycard readers, locks)
3. Shipping and receiving bays

ii. **Why It's Critical:** Physical breaches allow for theft and unauthorized access to IoT equipment, and even hardware tampering. Because warehouses store the IoT Doohickeys before distribution, securing the warehouse's physical environment is part of preventing the compromise of the supply chain.

3. Control Matrix

Control Type →	Preventative	Detective	Corrective	Deterrent
Administrative Controls	**Controls:** IoT Security Policy; Acceptable Use Policy; Vendor Supply-Chain Security Policy. **Asset Mapping:** Data, IoT endpoints, vendor processes, employee access. **Implementation:** Draft, approve, publish policies; yearly acknowledgement; add vendor requirements to contracts; annual review.	**Controls:** Log Review Procedures; Incident Reporting Policy; Quarterly Access Reviews. **Asset Mapping:** Networks, apps, identities. **Implementation:** Weekly log review; mandatory incident reporting steps; HR + IT conduct quarterly access audits.	**Controls:** Security Awareness Retraining; Corrective Action Program; Post-Incident Reviews. **Asset Mapping:** People, apps, and operational processes. **Implementation:** Retraining after incidents; enforce corrective actions; document lessons learned; update policies.	**Controls:** Disciplinary Policy; Published Security Standards; NDA/Confidentiality Agreements. **Asset Mapping:** All asset areas—deterring misuse. **Implementation:** Define disciplinary tiers; post standards on intranet; require NDAs for staff/vendors.
Technical Controls	**Controls:** MFA; IoT Network Segmentation; Web Application Firewall (WAF). **Asset Mapping:** Networks, apps,	**Controls:** SIEM Alerts; EDR Monitoring; Database Activity Monitoring. **Asset Mapping:** Data, endpoints,	**Controls:** Patch Management; Backup/Restore System; IoT Firmware Rollback. **Asset Mapping:** Infrastructure, apps,	**Controls:** Login Banner Warnings; Account Lockout Thresholds; Internal Honeypot. **Asset Mapping:** Identities, networks.

	IoT devices, customer data. **Implementation:** Deploy MFA; separate IoT VLANs; configure WAF rules with hosting provider.	apps. **Implementation:** Centralize logs; deploy EDR agents; tune DB monitoring alerts.	IoT systems. **Implementation:** Weekly patch window; offsite backups; maintain signed firmware images for rollbacks.	**Implementation:** Apply banners via IAM/MDM; configure lockout policies; deploy honeypot to detect brute-force attacks.
Physical Controls	**Controls:** Badge Access Control; Locked IoT Storage Cages; Visitor Escort Policy. **Asset Mapping:** Facilities, IoT inventory, warehouse devices. **Implementation:** Install card readers; secure IoT cages; train staff on escorting visitors.	**Controls:** CCTV Monitoring; Tamper-Evident Seals; Warehouse Environmental Sensors. **Asset Mapping:** Facilities, IoT hardware in storage. **Implementation:** Retain footage 90 days; inspect seals on intake; set sensor alerts.	**Controls:** Physical Incident Recovery Plan; Replace Compromised IoT Stock; Rekeying/Badge Revocation. **Asset Mapping:** Facilities, IoT devices, physical assets. **Implementation:** Define recovery steps; quarantine & replace affected devices; revoke badges on termination.	**Controls:** Security Guards; Exterior Lighting; Surveillance Signage. **Asset Mapping:** Facilities and stored hardware. **Implementation:** Contract guards; add motion lighting; post surveillance notices at all entrances.

4. Risk Matrix

Risk	Likelihood	Impact	Score
IoT firmware tampering	4	5	20
Payment card data breach	3	5	15
Phishing leading to credential theft	5	3	15
Ransomware in warehouses	3	5	15
E-commerce website downtime	4	4	16
Insider misuse of admin accounts	3	4	12
Lost or stolen employee laptop	4	3	12
API abuse of web or mobile apps	3	4	12
Network intrusion via poorly secured IoT devices	4	4	16
Break-in at distribution center	2	4	8

5. Compliance Mapping

PCI Requirement	How Our Controls Support It
1 – Secure Network	WAF, network segmentation, firewalls
2 – Secure Configurations	Patch management, hardened images
3 – Protect Cardholder Data	Database monitoring, encryption policies
4 – Encrypt Transmission	TLS enforcement, secure API gateways
5 – Malware Protection	EDR, endpoint controls
6 – Secure Systems & Apps	Patch cycles, code review policies
7 – Access Control	MFA, least-privilege access reviews
8 – Authentication	Account lockouts, MFA enforcement
9 – Physical Security	Access badges, locked IoT cages
10 – Logging & Monitoring	SIEM alerts, log review procedures
11 – Vulnerability Testing	Internal scans, WAF tuning
12 – Security Policy	All administrative controls

NIST Cybersecurity Framework Mapping

1. **Identify (ID)**
    1.1. Asset inventories, IoT policy, and supply chain policy.
2. **Protect (PR)**
    2.1. MFA, segmentation, WAF, and physical access control.
3. **Detect (DE)**
    3.1. SIEM alerts, CCTV, EDR, environmental sensors.
4. **Respond (RS)**
    4.1. Incident reporting, IR procedures, and post-incident review.
5. **Recover (RC)**
    5.1. Backup restoration, firmware rollback, recovery plans.

6. **Security Operations Plan**
    a. **Logging and Monitoring**
        i. **Doohickey Depot** Centralizes all logs into the company SIEM platform.
        ii. **Sources will include**
            1. firewalls,
            2. IoT management platforms,
            3. web servers,
            4. payment systems,
            5. active directory/identity providers.
            6. EDR
        iii. **Log Retention:** 12 Months
        iv. **Alerting:**

1. Failed MFA
2. Unusual IoT traffic
3. Payment system anomalies
4. Privilege escalation events
5. Data exfiltration indicators

b. Incident Detection

i. Primary Detection Mechanisms:

1. SIEM Rules
2. EDR Analytics
3. Warehouse CCTV

c. Incident Response

i. Detection
ii. Analysis
iii. Containment
iv. Eradication
v. Recovery
vi. Post-Incident Review

d. Team Roles

i. **SOC Analyst:** First responder, log monitoring, alert triage
ii. **Incident Response Lead:** Coordinates technical response
iii. **IT Admin:** Executes containment & system fixes
iv. **Compliance Officer:** Ensures PCI/NIST alignment
v. **Executive Stakeholders:** Approve major decisions during severe incidents

7. Executive Summary

IoT-enabled "Doohickey" devices for both consumer and industrial markets are the focus of Doohickey Depot, a mid-sized retail and online business. The company is increasingly vulnerable to cyberthreats that could affect customer confidence, business continuity, and regulatory compliance as it grows more dependent on connected devices and online sales platforms.

This security program creates an organized method for safeguarding Doohickey Depot's vital assets, including data, applications, infrastructure, IoT devices, employees, and physical locations. To direct the application of administrative, technical, and physical security controls, a thorough control matrix was created. The four goals of each control type—preventative, detective, corrective, and deterrent—ensure comprehensive coverage throughout the risk landscape of the business.

Key preventative controls include multi-factor authentication, IoT network segmentation, formal IoT security policy, and locked storage for device inventory. Detective controls such as SIEM log monitoring, EDR analytics, CCTV surveillance, and

database activity monitoring provide early identification of suspicious activity. Corrective controls, including patch management, firmware rollback capabilities, and incident review procedures, ensure the organization can recover quickly from potential incidents. Deterrent measures like disciplinary policies, access badges, login banners, and visible security signage reduce the likelihood of insider misuse or physical tampering.

The company's risk assessment identified ten significant threats, including IoT firmware tampering, phishing attacks, payment card data breaches, ransomware affecting warehouse operations, and supply-chain manipulation. These risks were ranked by likelihood and impact to prioritize mitigation efforts. Selected security controls directly support compliance with PCI DSS requirements for payment information data protection and align with the NIST Cybersecurity Framework's Identify-Protect-Detect-Respond-Recover structure.

Doohickey Depot's Security Operations Plan outlines how the company monitors, detects, and responds to cybersecurity events. Centralized SIEM logging, EDR monitoring, IoT telemetry review, and physical security alerts create unified detection capability. The incident response process defines clear steps for analysis, containment, eradication, and recovery, with assigned responsibilities across IT, security, compliance, and leadership teams.

Overall, this security program enhances the confidentiality, integrity, and availability of Doohickey Depot's systems and data while supporting operational resilience. By strengthening IoT security, improving workforce readiness, tightening access controls, and adopting industry-aligned best practices, Doohickey Depot positions itself to manage emerging risks and maintain customer trust in a highly competitive and technology-driven market.